



— AXE G · LA RÉPLICATION D'ANNUAIRE

Le coffre-fort qui se copie à distance

Vos contrôleurs de domaine sont sous clé, dans une salle sécurisée. Mais leur contenu, lui, voyage sur le réseau — et sait se faire demander.

Personne n'entre dans la salle des serveurs sans badge, sans escorte, sans traçabilité. Cette protection physique est réelle, et utile. Elle protège la machine. Elle ne protège pas, en revanche, ce que la machine accepte d'envoyer à quiconque sait le lui demander dans les règles.

■ L'IDÉE REÇUE

« Pour voler les mots de passe du domaine, il faut accéder physiquement à un contrôleur de domaine. »

En réalité — la réplication est une fonction d'administration à **distance**. Détenir deux droits étendus précis suffit à demander à un contrôleur de domaine de vous **répliquer tous ses secrets** — depuis n'importe quel poste, en vous faisant passer pour un autre contrôleur. C'est l'attaque DCSync.

1 cmd

Une commande, tous les secrets

Avec les bons droits, une seule commande suffit à obtenir le condensat de n'importe quel compte — y compris celui de krbtgt, la clé qui signe tous les tickets Kerberos du domaine.

AU SOMMAIRE DE CETTE FICHE

1

Le déclic

L'idée reçue, l'analogie du coffre, l'impact métier.

2

Le mécanisme

La réplication, les deux droits, le compte krbtgt.

3

La salle des machines

Vérifier, comprendre l'attaque, corriger et détecter.

1

NIVEAU 1 — POUR COMPRENDRE

Le déclic

Nous avons tous en tête la même image rassurante du contrôleur de domaine : une machine précieuse, rangée dans une salle fermée à clé, sous vidéosurveillance, dont l'accès physique est strictement contrôlé. Pour atteindre les mots de passe qu'elle protège, pense-t-on, il faudrait franchir cette porte.

Cette protection physique existe bel et bien. Mais elle répond à une question — qui peut toucher la machine — alors que le vrai sujet en est une autre : qui peut lui demander de parler.

Prenons une image. Une banque garde ses lingots dans une chambre forte, derrière une porte blindée. Personne n'y entre. Pourtant, la banque possède plusieurs agences, et il faut bien que leurs coffres restent synchronisés. Les banques ont donc mis en place une procédure interne : une agence peut, à distance, demander à une autre une copie certifiée du contenu de

son coffre. Pas besoin d'entrer dans la chambre forte — il suffit d'être reconnu comme une agence légitime et de connaître la procédure.

Active Directory fonctionne exactement ainsi. Un domaine compte plusieurs contrôleurs, et ils doivent en permanence rester identiques : c'est la **réplication**. Pour cela, un contrôleur sait demander à un autre : « envoie-moi les dernières modifications ». L'autre s'exécute — y compris pour les mots de passe.

Toute la question devient alors : **qui le domaine accepte-t-il comme une « agence légitime » ?**

La réponse n'est pas « une machine dans la salle des serveurs ». C'est « quiconque détient le bon droit ». Et si ce droit a été accordé, par erreur ou par négligence, à un compte qui n'aurait jamais dû l'avoir, alors ce compte peut réclamer une copie certifiée du coffre — sans jamais s'approcher de la porte blindée.

« La serrure de la salle des serveurs protège la machine. Elle ne protège pas ce que la machine accepte d'envoyer. »

POURQUOI ÇA COMPTE — L'IMPACT MÉTIER

Cette idée reçue est dangereuse parce qu'elle oriente toute la défense au mauvais endroit. On investit dans le contrôle d'accès physique, dans le badge et la caméra — protections utiles, mais qui ne couvrent pas le risque réel. Le vol des secrets du domaine ne demande pas de présence physique : il demande un droit, et ce droit se distribue, s'hérite et s'oublie dans les permissions de l'annuaire. Pire : une fois les secrets répliqués, l'attaquant détient de quoi se forger des accès qui survivront à presque toutes les remédiations. La bonne défense n'est pas une meilleure serrure de porte — c'est de savoir, précisément, qui peut demander au coffre de se copier.

2

NIVEAU 2 — LE FONCTIONNEMENT RÉEL

Le mécanisme

La réplication d'annuaire repose sur un protocole nommé **MS-DRSR**. C'est lui qui permet aux contrôleurs de domaine de se synchroniser entre eux. La fonction clé s'appelle **DRSGetNCChanges** : un contrôleur l'invoque pour demander à un autre « donne-moi les objets modifiés ». La réponse inclut, quand c'est demandé, les **attributs secrets** — dont **unicodePwd**, qui porte le condensat du mot de passe de chaque compte.

Ce mécanisme est parfaitement légitime : sans lui, un domaine multi-contrôleurs ne pourrait pas exister. Le problème n'est pas la fonction, c'est **qui a le droit de l'appeler**. Et ce droit ne tient pas à la nature de l'appelant — machine ou utilisateur, peu importe — mais à deux permissions précises, posées sur l'objet racine du domaine.

Les deux clés de DCSync

DCSync ne fonctionne que si l'attaquant réunit deux droits étendus. Pris isolément, chacun semble technique et anodin. Réunis, ils ouvrent le coffre.



Le scénario s'écrit alors tout seul. Un attaquant qui contrôle un compte doté de ces deux droits lance, depuis n'importe quel poste, un outil qui parle le protocole de réplication. Il s'adresse à un contrôleur de domaine en se présentant comme un pair, et invoque **DRSGetNCChanges** en ciblant le compte de son choix. Le contrôleur, ne voyant qu'une réplication conforme demandée par un détenteur légitime du droit, répond — et livre le condensat. L'attaquant n'a pas « piraté » le contrôleur : il lui a simplement demandé poliment, avec les bonnes autorisations.

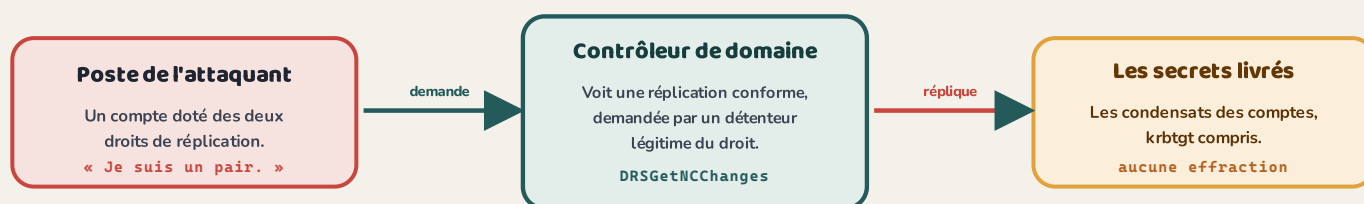


Schéma 1 — DCSync : l'attaquant ne force aucune porte, il demande une réplication dans les règles.

SOUS L'ÉCORCE

Pourquoi l'obsession pour le compte **krbtgt** ? Parce qu'il n'est pas un compte comme les autres : son condensat est la **clé qui signe tous les tickets Kerberos du domaine**. Qui le détient peut forger un « Golden Ticket » — un TGT entièrement fabriqué, valable pour n'importe quel compte, n'importe quel privilège, et plusieurs années durant. Et voici ce qui rend la situation si grave : changer le mot de passe d'un administrateur ne sert à rien si l'attaquant a le **krbtgt** ; il se reforge un ticket. La seule remédiation est de réinitialiser *deux fois* le compte **krbtgt** — une opération délicate. DCSync n'est donc pas qu'un vol de mots de passe : c'est l'obtention de la clé maîtresse qui rend tous les autres verrous décoratifs.

3

NIVEAU 3 — SUR LE TERRAIN

La salle des machines

Trois gestes, toujours dans le même ordre : **vérifier** qui détient les droits de réplication, **comprendre** ce qu'un attaquant en ferait, puis **corriger et détecter**.

1 Vérifier

Commençons par le diagnostic. Cette commande lit la liste de contrôle d'accès de l'objet racine du domaine et n'affiche que les entrées portant un droit de réplication — à exécuter depuis un poste disposant du module Active Directory (RSAT).

LA COMMANDE DU JOUR — QUI PEUT RÉPLIQUER LE DOMAINE

```
PS C:\> (Get-Acl "AD:DC=adcompagnon,DC=lab").Access |
>> Where-Object { $_.ObjectType -in $guidsReplication } |
>> Select-Object IdentityReference, ActiveDirectoryRights
```

Mot à mot. On lit la DACL de la racine du domaine, puis on ne retient que les ACE dont le type correspond aux GUID des droits étendus de réplication. **Tout bénéficiaire affiché qui n'est ni un contrôleur de domaine, ni un groupe d'administration connu, est une anomalie à investiguer sans délai.**

```
Administrateur : Windows PowerShell

PS C:\> ... | Select IdentityReference, ActiveDirectoryRights
```

IdentityReference	Droit de réplication
ADCOMPAGNON\Domain Admins	Get-Changes / -All
ADCOMPAGNON\Enterprise Admins	Get-Changes / -All
ADCOMPAGNON\svc-sauvegarde	Get-Changes / -All

! L'anomalie

Les deux premières lignes sont des groupes d'admin attendus.

Un compte de service ne réplique jamais le domaine.

Capture simulée — la DACL de la racine sur adcompagnon.lab : un compte de service de trop.

2 Comprendre l'attaque

Le droit de réplication mal attribué n'est pas une faille isolée : c'est la dernière marche avant la prise totale du domaine. Voici la chaîne.

CE QU'UN ATTAQUANT EN FAIT

1 Le repérage du droit

Il cartographie l'annuaire avec **BloodHound**, qui signale explicitement tout compte disposant de **DCSync** sur le domaine — droit direct ou hérité.

2 La réplication ciblée

Depuis ce compte, il lance **mimikatz lsadump::dcsync** ou **impacket-secretsdump**, en ciblant d'abord le compte **krbtgt**.

3 Le Golden Ticket

Avec le condensat de **krbtgt**, il forge un TGT arbitraire : n'importe quel compte, n'importe quel privilège, une validité de plusieurs années. Le domaine est à lui.

4 La persistance totale

Il réplique l'ensemble des condensats du domaine. Changer les mots de passe n'y suffira plus : il dispose d'un stock de clés et de la signature maîtresse.

La chaîne entière repose sur le droit de réplication mal placé. **Retirez-le, et DCSync n'a plus de point de départ.**

3 Corriger et détecter

La correction tient en trois gestes. Le premier fait le ménage dans les droits, le deuxième installe une surveillance, le troisième prépare le pire.

1 Réserver le droit de réplication

Le droit de réplication ne doit appartenir qu'aux contrôleurs de domaine et aux groupes d'administration de l'annuaire. Tout autre bénéficiaire — compte de service, application, utilisateur — doit en être retiré, après vérification de son usage réel.

● ● ● RETIRER UN DROIT DE RÉPLICATION ILLÉGITIME

```
PS C:\> $racine = "AD:DC=adcompagnon,DC=lab"
PS C:\> $acl = Get-Acl $racine
PS C:\> $acl.Access | Where-Object IdentityReference -eq 'ADCOMPAGNON\svc-sauvegarde' |
>>     ForEach-Object { $acl.RemoveAccessRule($_) }
PS C:\> Set-Acl $racine -AclObject $acl
```

2 Surveiller la réplication

Une réplication légitime vient toujours d'un contrôleur de domaine. Toute demande de réplication émise par une source qui n'en est pas un est, par construction, suspecte — et doit déclencher une alerte.

3 Préparer la réinitialisation du krbtgt

Documentez et testez à froid la procédure de double réinitialisation du compte `krbtgt`. Le jour où une compromission est suspectée, elle doit pouvoir être exécutée vite et sans hésitation : c'est le seul moyen d'invalidier un Golden Ticket.

Détecter — le bon événement

DCSync est furtif — il ne touche pas le disque du contrôleur — mais la demande de réplication, elle, passe par le réseau et se journalise.

ID 4662 « Une opération a été effectuée sur un objet ». C'est l'événement clé : lorsqu'il porte sur l'objet domaine et mentionne les **GUID des droits de réplication**, il signale un appel à `DRSGetNCChanges`. Si le compte à l'origine n'est pas un contrôleur de domaine, c'est une alerte de gravité maximale.

Réseau Un trafic de réplication (RPC **MS-DRSR**) provenant d'une adresse qui n'est pas celle d'un contrôleur de domaine est un signal fort, repérable côté supervision réseau.

Pour une **chasse proactive**, ce filtre liste les comptes *utilisateurs* dotés d'un droit de réplication — ceux qui ne devraient jamais l'avoir :

● ● ● CHASSE — DÉTENTEURS INATTENDUS DU DROIT DE RÉPLICATION

```
PS C:\> (Get-Acl "AD:DC=adcompagnon,DC=lab").Access |
>> Where-Object { $_.ObjectType -in $guidsReplication } |
>> Select-Object IdentityReference -Unique
```

OBSERVATEUR D'ÉVÉNEMENTS — JOURNAL SÉCURITÉ

Event ID 4662

Compte : ADCOMPAGNON\svc-sauvegarde
Objet : DC=adcompagnon,DC=lab
Propriétés : **Replicating Directory Changes All (GUID 1131f6ad...)**
Origine : **poste de travail – pas un contrôleur de domaine**

! Réplication demandée par un compte non-DC — signature d'un DCSync en cours.

VU SUR LE TERRAIN

Lors de l'audit d'une organisation de taille moyenne, l'équipe de sécurité cherche le chemin le plus court vers les clés du domaine. Les contrôleurs sont à jour, bien protégés physiquement, et aucun administrateur n'a de mot de passe faible. La cartographie de l'annuaire révèle pourtant une ligne inattendue : le compte de service d'une ancienne solution de sauvegarde disposait, sur la racine du domaine, des deux droits de réplication — l'éditeur les avait réclamés à l'installation « pour sauvegarder l'état système ». Le mot de passe de ce compte traînait dans un fichier de configuration. En une commande, l'équipe répliquait le condensat de `krbtgt`, et forgeait un Golden Ticket. La forteresse n'avait pas été percée : on lui avait simplement demandé, dans les règles, de se recopier.

LE COIN DU DÉCIDEUR

Protéger les secrets du domaine, ce n'est pas seulement verrouiller la salle des serveurs : c'est **maîtriser qui a le droit de demander une réplication**. Ce droit est l'un des plus sensibles de tout l'annuaire — il équivaut, en pratique, à la possession des clés du domaine. La bonne question pour votre équipe n'est pas « nos contrôleurs de domaine sont-ils bien gardés ? », mais « **avons-nous la liste exacte de qui peut les faire répliquer ?** ». Et une seconde, tout aussi décisive : « **saurions-nous réinitialiser le compte `krbtgt` en cas de doute ?** ». Si l'une des deux réponses manque, c'est la priorité.

L'ÉNIGME DU COMPAGNON — N°07

Sur `adcompagnon.lab`, l'équipe a vérifié la DACL de la racine : aucun compte n'y détient directement les droits de réplication, hormis les groupes d'administration légitimes. L'audit est déclaré conforme. Pourtant, un test d'intrusion réussit un DCSync depuis un compte ordinaire. **D'où vient le droit ?**

LA RÉPONSE DU COMPAGNON

Le droit de réplication n'a pas besoin d'être posé *directement* sur la racine pour fonctionner — il suffit qu'il soit **effectif**. Deux chemins indirects, déjà croisés dans ce magazine, le rendent possible. Premier chemin : le compte ordinaire est membre, parfois via une imbrication de groupes, d'un groupe qui détient le droit ; l'audit « compte par compte » ne le voit pas, l'audit « droits effectifs » oui. Second chemin — l'angle mort réel : le compte dispose d'un `GenericAll` ou d'un `WriteDACL` sur l'objet domaine, hérité d'une ACE mal placée (le N°03). Il n'a pas le droit de réplication... mais il a le droit de *se l'accorder*, puis de l'exercer. Vérifier qui détient DCSync ne suffit pas : il faut vérifier qui peut *devenir* détenteur de DCSync.

LE GLOSSAIRE

Réplication — synchronisation permanente des données entre les contrôleurs d'un domaine.

Contrôleur de domaine — serveur qui héberge l'annuaire et authentifie les comptes.

MS-DRSR — le protocole de réplication d'annuaire entre contrôleurs de domaine.

DRSGetNCChanges — la fonction du protocole qui demande les objets modifiés, secrets compris.

DCSync — attaque consistant à demander une réplication pour voler les condensats de mots de passe.

Get-Changes — droit étendu autorisant la réplication des modifications de l'annuaire.

Get-Changes-All — droit étendu étendant la réplication aux attributs secrets.

Condensat — empreinte cryptographique d'un mot de passe, stockée dans l'annuaire.

krbtgt — compte dont la clé signe tous les tickets Kerberos du domaine.

Golden Ticket — TGT forgé à partir de la clé `krbtgt` ; accès total et durable au domaine.

DACL — liste de contrôle d'accès d'un objet ; voir le N°03 du magazine.

Droit effectif — droit réellement applicable, direct, hérité ou obtenu via un autre droit.



DANS LE PROCHAIN NUMÉRO

N°08 — Les stratégies de groupe : l'outil qui configure tout — et peut tout exécuter

Comment un partage réseau modifiable transforme la GPO en mécanisme de déploiement pour l'attaquant.